

IT SOP — Password Reset and Account Recovery

Document ID: IT-SOP-014

Version: 3.2

Last Updated: March 2025

Owner: IT Security Operations

Purpose

This standard operating procedure describes the process for employees to reset forgotten passwords or recover locked accounts for their Acme Corp identity (used for Okta SSO, email, Slack, Workday, and all SSO-integrated applications).

Prerequisites

Before attempting a password reset, confirm:

- You have enrolled at least one MFA method in Okta (authenticator app, hardware token, or SMS).
- You have access to your backup email on file (usually personal).
- You are not using a public or shared computer.

Self-Service Reset — Standard Path

If you can still receive email or have a working MFA device:

1. Go to `https://login.acme.example`` and click ****Forgot password?****.
2. Enter your Acme email address and click ****Next****.
3. Choose a recovery method:
 - Authenticator app (Okta Verify) — preferred
 - Hardware token (YubiKey)
 - SMS code to registered phone
4. Complete MFA challenge.
5. Create a new password following the complexity rules (see below).
6. Sign back in. SSO-integrated apps should accept the new password

within 5 minutes.

Expected time: **under 5 minutes**.

Password Complexity Requirements

New passwords must meet ALL of the following:

- Minimum 14 characters
- At least 1 uppercase letter
- At least 1 lowercase letter
- At least 1 number
- At least 1 symbol (!@#\$%^&*()_+~[]{}|;:,.<>?)
- Cannot match any of your last 10 passwords
- Cannot contain your first name, last name, or username
- Cannot be a dictionary word or common substitution (e.g. `P@ssw0rd`)

Passwords expire every **180 days**. You will be prompted to change 14 days before expiration.

Recovery When Locked Out of MFA

If you have lost your MFA device AND cannot access email:

1. From a different device, go to `https://help.acme.example/recovery``.
2. Click **Account recovery — no MFA access**.
3. Enter your Acme email and employee ID (on your badge).
4. You will be prompted to answer three security questions set during onboarding.
5. If successful, a one-time recovery link is sent to your backup email on file.
6. The link expires in **30 minutes**.

If you cannot answer security questions or do not have backup email:

- Call the IT Helpdesk at **1-800-ACME-HELP** (1-800-226-3435).
- Have your manager ready to verify identity via video call.
- The helpdesk will reset your account within 30 minutes during business hours (M–F 6am–9pm PT), or up to 4 hours after-hours.

Recovery When Locked Out of Everything

If you cannot access ANY Acme system AND do not have your badge:

1. Contact your manager directly via personal phone.
2. Your manager opens a P1 ticket with IT Security on your behalf.
3. You will need to visit an Acme office and present government-issued photo ID to an IT administrator for in-person verification.
4. After verification, IT will reset your account and schedule a new MFA enrollment session.

This path typically takes **4–24 hours** depending on office availability.

Accounts Locked Due to Suspicious Activity

If your account was locked automatically due to suspicious activity (e.g. too many failed login attempts, login from an unusual country):

- Check your personal email for an automated notification from `security@acme.example`.
- Use the self-service path above — the lock is usually cleared after a successful MFA challenge.
- If the lock persists, open a ticket with IT Security (NOT the general helpdesk) by emailing `security@acme.example`.

What NOT to Do

- Do NOT share your password with anyone, including IT staff. IT will never ask for your password.
- Do NOT reuse passwords from personal accounts.
- Do NOT write your password on a sticky note or store it in a plain text file. Use the company-provided 1Password vault.
- Do NOT bypass MFA using backup codes unless strictly necessary.

Escalation

If the process above does not resolve your issue within 2 business days:

- Escalate to your IT Business Partner (listed on the intranet under IT > Business Partners).

- CC `itsec-leadership@acme.example`.
- Include ticket number, timeline, and steps already attempted.

Related Documents

- IT-SOP-002: MFA Enrollment
- IT-SOP-007: Acceptable Use Policy
- IT-POL-001: Information Security Policy